From phish to privilege: how threat actors attack Azure

Michael Michalos
Lazaros Katanas

#GLOBALAZURE 2026

Saturday, April 18th Athens, Greece

BIG THANK YOU TO OUR SPONSORS!

XLYTiCA
DATA UNLEASHED - FUTURE FORGED

ARISTÉVIN CONSULTING

Quest GROUP
Info Quest TECHNOLOGIES

cegeka

BEWISE

PREDICTA
ANALYTICS FOR DECISION MAKING

20 years InTTrust
Microsoft Solutions Partner

cloud dream team

ALEF

performance

BlueStream SOLUTIONS

NEUROSOFT

#GLOBALAZUREATHENS #GLOBALAZUREGREECE

Why cloud attacks are different

Cloud changes the game

Traditional On-Premises

- Physical perimeter controls
- Network-based segmentation
- Hardware-dependent access
- Slower lateral movement
- Centralized authentication

Modern Cloud Environment

- Identity becomes the perimeter
- Software-defined boundaries
- Token-based authentication
- Rapid privilege escalation paths
- Distributed trust relationships

Stage 1 – Initial Access

Getting the first foothold

Phishing to capture credentials or drive the user to a malicious flow

Push-based MFA fatigue to get approval

OAuth consent abuse to obtain access tokens without the user's password

Lot's of toolkits in the wild: Evilginx, GoPhish, Social-Engineer Toolkit and more.
And in the dark web: EvilTokens (NEW!)

MITRE ATT&CK (examples)

T1566 – Phishing
T1621 – Multi-Factor Authentication Request Generation
T1528 – Steal Application Access Token

Stage 2 – Entra ID Discovery

Learning the tenant

Account Discovery

Query user accounts, service principals, and managed identities to identify targets with elevated privileges or weak authentication

Application Discovery

Identify registered applications, service principals, and their permission grants to find exploitable trust relationships

Group Enumeration

List membership relationships to understand role-based access control and inheritance patterns across organizational units

Subscription Mapping

Enumerate Azure subscriptions, resource groups, and service deployments to scope the attack surface

MITRE ATT&CK (examples)

T1087 – Account Discovery
T1069 – Permission Groups Discovery
T1526 – Cloud Service Discovery
T1580 – Cloud Infrastructure Discovery

Stage 4 – Privilege Escalation

Becoming powerful

Abuse excessive permissions to gain higher roles

Exploit over-permissive app permissions (Graph/API) to act as the directory

Modify authentication controls to widen access (where privileges allow)

MITRE ATT&CK (examples)

T1098 – Account Manipulation
T1556 – Modify Authentication Process
T1078.004 – Valid Accounts: Cloud Accounts

Stage 5 – Persistence

Staying in the cloud

Account Creation

Register new user accounts with generic names, assign minimal permissions initially, and elevate later to avoid detection

Malicious Apps

Register OAuth applications with delegated permissions, configure redirect URIs to attacker-controlled endpoints

Credential Addition

Add certificates or client secrets to existing service principals, creating authentication bypasses without new accounts

MITRE ATT&CK (examples)

T1136 – Create Account
T1098 – Account Manipulation
T1556 – Modify Authentication Process

Phish → Entra ID Enumerate → Priv Esc → **Persistence** → Impact

Stage 6 – Impact

After privilege: business outcomes

Email Collection

Access mailboxes through Microsoft Graph API, export messages containing intellectual property, credentials, or sensitive business communications

Cloud Exfiltration

Copy files to attacker-owned Azure, OneDrive, or SharePoint locations, blending data transfer with legitimate cloud synchronization traffic

Resource Hijacking

Take over subscriptions through billing tampering, redeploy infrastructure for cryptomining, or hold resources for ransom

MITRE ATT&CK (examples)

T1114 – Email Collection
T1567.002 – Exfiltration to Cloud Storage
T1496 – Resource Hijacking

Where defenders can break the chain

Defense-in-depth mapped to stages

Phish-resilient MFA (FIDO2 / passkeys) + user protection

Conditional Access: risk-based, device compliance, block legacy auth

Least privilege + PIM + strong governance for app consent

Centralized logging + alerting on identity, role, and app changes

Incident response: revoke tokens, review apps/SPs, check role changes

Microsoft Security stack alignment

Signals across the chain – Defense in Depth

Perimeter + Network

DDoS Protection and Front Door (WAF) mitigate internet threats; VNets, NSGs, Firewall, and Private Endpoints limit exposure.

Compute + Application

Defender for Servers/Endpoint hardens hosts; Managed Identities, Defender for App Service/Containers, and API Management secure workloads.

Data + Identity

Key Vault, encryption, and Purview protect data; Entra ID enforces MFA, Conditional Access, RBAC, and PIM (least privilege).

Visibility + Defense in Depth

Defender for Cloud, Sentinel, Monitor, and Log Analytics drive detection/response; layered controls assume breach and limit blast radius.

Microsoft Defender XDR: identity + endpoint + email correlations

Defender for Cloud :Unified security posture management and advanced threat protection

Entra ID: Conditional Access, Identity Protection, PIM

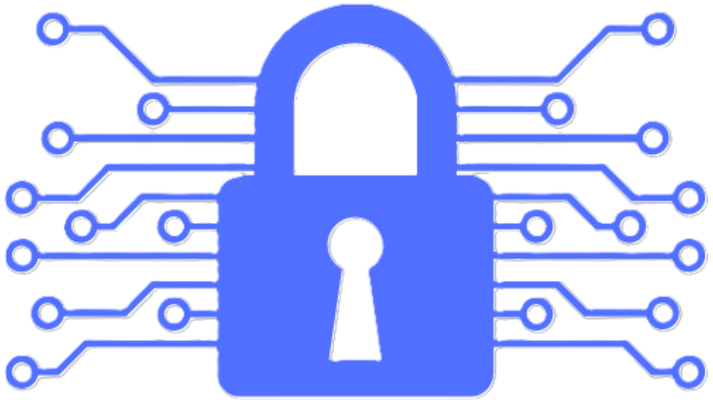
Phish → Valid Account → Entra ID Enumerate → Priv Esc → Persistence → Impact

Key takeaways

What everyone should remember

Phishing is still the start, but cloud-native attacks lean on tokens and apps

Design for resilience: least privilege + strong auth + continuous monitoring



Monitor identity and admin actions like you monitor endpoints

Permissions (roles, app grants, service principals) are the real attack surface

Thank you!

From phish to privilege: how threat actors attack Azure